

Category: Information Security Legal and Compliance	Policy Title: Information Security Policy Document Number: 6900 Effective Date: September 1, 2025 This policy item applies to: Community Colleges State-Operated Campuses Statutory Colleges System Administration Entities, Affiliates, and Third-Party Service Providers
Responsible Office: Office of the Chief Operations Officer	

Table of Contents

Summary	2
Policy Overview	2
Applicability	3
Information Security Management Program	4
Information Security Risk Management	6
Security Incident Notification	7
Access Management	8
Data Backups	8
Data Encryption	9
Firewalls	10
Network Infrastructure Management	10
Network and Endpoint Security	11
Vulnerability Management	12
Incident Response	13
Definitions	13
Other Related Information	14
Procedures	15
Forms	15
Authority	15
History	16

Summary

Responsible System Office: Office of the Chief Operations Officer

Responsible Campus Office: Office of the Campus President

The State University of New York (“SUNY” or “State University”) is committed to securing and protecting the information within its possession. As an institution of higher education operating in New York State, SUNY must comply with federal and state confidentiality and information safeguarding laws, as well as meet data protection requirements imposed by its accrediting agency, the Middle States Commission on Higher Education (“MSCHE”).

SUNY’s core academic mission and strategic goals require policies, procedures, controls, monitoring, and verifications to protect the information it stores, possesses, or transmits through the normal course of operations. In an increasingly digital environment, the broad range of information central to the facilitation of academic programs, research, student services, and overall business operations in the State University’s possession has made such information one of SUNY’s most important assets, requiring increased vigilance with respect to storing, sharing, and using data that builds on existing SUNY policy and practice.

Public

Section 1: *Policy Overview*

The SUNY Information Security Policy 6900 establishes a comprehensive framework for safeguarding the confidentiality, integrity, and availability of the institution’s digital assets, information systems, and information technology (IT) infrastructure. This policy will serve as the overarching organizational directive for all subordinate security policies and standards. The policy defines mandatory minimum information security requirements while accommodating institution-specific adaptations.

The policy’s primary objectives are to:

1. Maintain academic freedom and research collaboration within a secure IT ecosystem.
2. Ensure the protection and privacy of sensitive data, encompassing academic, health, research, financial, and personally identifiable information (PII) of faculty, staff, and students.
3. Preserve the integrity of all data stored, processed, and transmitted across institutional systems.
4. Guarantee the availability and operational continuity of information systems, networks, and resources critical to the institution’s core missions.
5. Implement a risk-based information security management framework, aligning protective measures with institutional priorities and obligations.
6. Cultivate a culture of information security awareness and compliance among all institutional stakeholders.

7. Establish a unified approach to cyber risk mitigation and resilience enhancement throughout the SUNY system.

This policy establishes the responsibilities of all SUNY Institutions and workforce members are responsible for:

- Implementation and maintenance of comprehensive, multi-layered, and redundant protection mechanisms for information assets and IT infrastructure.
- Performance of regular risk assessments to effectively manage and adequately respond to identified security risks.
- The development and continuous improvement of institutional incident response capability and business continuity planning.
- Implementation and management of security tools and systems for continuous security monitoring and anomaly detection.
- Ensure compliance with applicable legal, regulatory, and contractual obligations.

Through adherence to this policy, SUNY aims to establish a secure, resilient, and stable IT environment that facilitates its mission-critical operations while safeguarding its information assets. This policy synthesizes standards-based and risk-based methodologies, tailored to the unique requirements of our educational ecosystem, ensuring a baseline security posture while enabling localized operational flexibility and governance.

This policy acts as an umbrella document to all other security policies and associated standards.

Public

Section 2: *Applicability*

This policy applies to:

- State-operated institutions and community colleges.
- Statutory colleges, with respect to sharing of information with other SUNY institutions.
- System Administration, the Information Technology and Exchange Center (ITEC), and the Student Information and Campus Administrative Systems (SICAS) program.
- Entities, affiliates, and third-party service providers that use the State University's data and or information systems for their operations or the delivery of services.

And encompasses:

- All institutional data, including administrative, teaching and learning, clinical, and research. Institutional data is any data owned, licensed by, or under the direct control of SUNY, whether stored locally or with a cloud provider.
- Third-party vendors who collect, process, share, or maintain university institutional data, whether managed or hosted internally or externally.

In accordance with this policy, SUNY institutions are responsible for:

- Implementing an Information Security Program, as outlined in this policy, and other related SUNY-wide policies and procedures; and
- Following appropriate security protocols as outlined in this policy, related policies, and applicable university wide standards, applicable guidelines, and procedures, designed to protect and safeguard the institutional data assets is in their possession.
- Ensuring adherence to all relevant federal and state laws, rules, and regulations that establish the precise safeguards required to protect the integrity and extent of research or work conducted at the institution. This entails complying with legal obligations pertaining to information security, privacy, and data protection standards relevant to the institution's operations and data nature.

Entities covered by this policy will hereafter be referred to as “institutions.”

Section 3: *Information Security Management Program*

Policy Objective: Set institutional strategy, goals, objectives, and establish an information security governance process.

Section Overview

This section outlines the essential governance framework and core components each institution must implement to safeguard digital assets and information. It establishes the foundational pillars of an effective information security program, ensuring alignment with organizational objectives and regulatory mandates. The requirements promote a robust security posture through structured leadership, comprehensive policies, periodic evaluations, personnel education, and financial risk mitigation measures.

3.1 Program Establishment

Institutions must establish and implement an information security program (ISP). The ISP must deploy administrative, technical and operation controls to ensure the confidentiality, integrity and availability of the institution’s data and systems. ISP must incorporate an information security risk management process for identifying and responding to information and cyber security threats.

3.2 Information Security Program Governance

Each institution’s program must establish and implement the following ISP governance structure.

3.2.1 Information Security Program Lead

SUNY institutions must designate a qualified individual to be responsible for the oversight and implementation of the ISP and provide that individuals’ contact information to the SUNY CISO. The qualified individual may have other non-cybersecurity responsibilities as well.

3.2.2 Exception Process

Exceptions to Sections 4 through 13 of this policy are permitted when assessed and approved using a risk-based approach and properly documented. Exception requests must be approved by the designated ISP lead and a member of the institution's executive leadership and retained for record keeping. Exception requests must include the following information:

- Why the exception is needed.
- The duration of the exception request.
- Compensating controls that are in place to mitigate risks associated with the exception.

Exception requests may include a cost-benefit analysis.

3.2.2 Information Security Program Plan

Policy Objective: Develop an information security plan that aligns to an institution's mission, values, and objectives.

The ISP plan must include:

- Documentation of the plan's goals and major changes to the plan.
- External and internal requirements the institution is subject to.
- Threats and vulnerabilities identified through a risk assessment.
- Security controls deployed.
- Evaluation and testing of control effectiveness.

The elements above represent a baseline set of requirements for the ISP. Institutions are encouraged to add additional elements as necessary.

3.2.4 Institutional Policy Creation

Each institution must develop and maintain campus-specific information security policies that align with their unique strategy, goals, operational objectives and risk profile. These policies must adhere to the overarching principles and requirements set forth in SUNY system's Information Security Policy and the SUNY IT Standards, while addressing the specific needs, challenges, and risk landscape of the individual campus. Policies must not supersede any applicable laws or regulations. These policies must be regularly reviewed and updated to reflect changes in the institutional risk landscape, operational needs, evolving threats, and legal requirements.

3.2.5 Information Security Program Reporting

Each institution's designated qualified individual annually will prepare a written report on program status, effectiveness and material risks to the ISP to be provided to their institution's executive leadership for review and comment.

3.3 Information Security Program Elements

Each institution's program must establish and implement the following program elements into the ISP.

3.3.1 User Training

The institution must offer annual information security awareness, education and training to all individuals who access SUNY institution information assets and systems. The institution may, at their discretion, mandate additional training and compliance activities for faculty, staff, and personnel based on their access to sensitive or critical data or systems.

3.3.2 Cyber Breach Insurance

Institutions must obtain insurance for the costs that could result from an information security breach. Cybersecurity insurance will cover costs that flow from breach discovery, mitigation, and notification, and for the community colleges, liability costs. For State-operated campuses, the Court of Claims fund covers liability expenses.

Institutions must, to the extent feasible, require third parties who either handle operationally necessary data or provide essential IT services to maintain adequate insurance coverage. This insurance must be sufficient to cover potential losses arising from information security incidents or data breaches, in accordance with New York State law. The requirement applies to third parties integral to the institution's operations or data management, ensuring financial protection in the event of security compromises.

Public

Section 4: *Information Security Risk Management*

Policy Objective: Establish and maintain a comprehensive information security risk management framework that enables senior management to effectively identify, assess, mitigate, and monitor information security risks. This framework will support informed decision-making, align with the institution's risk appetite, strategic objectives, and ensure compliance with applicable laws, regulations, and industry standards.

4.1 Information Security Risk Management Process

Institutions must establish and maintain a formal information security risk management process. Institutions must identify, analyze, and evaluate information security risks to their assets, data, and operations, and develop appropriate risk responses.

4.2 Risk Assessment

Institutions must perform a risk assessment on an iterative basis to assess the risk to institutional operations, assets, and information, resulting from the operation of systems and the associated processing, storage, or transmission of institutional information. Risk assessments may be done internally or by third parties and must consider the following elements:

- Threats and vulnerabilities that could adversely affect institutional data or systems.
- Risks associated with third party vendors who collect, process, share, or maintain university institutional data.
- A rating of risks to determine the prioritization of mitigation.

The elements above represent a baseline set of requirements for the risk assessment. Institutions are encouraged to add additional elements as necessary.

4.3 Asset Inventory

Institutions must maintain a comprehensive and up-to-date inventory of all critical systems whose unavailability would materially impact operations. This inventory must include:

- Hardware, software, and network components essential to core business functions.
- Systems that store, process, or transmit sensitive data.
- Infrastructure supporting key operational processes.
- Backup and recovery systems critical for business continuity.
- Documentation of deprecated protocols or cryptographic algorithms.
- Documentation of unsupported (End of-Life (EOL)) systems.

The inventory must be reviewed regularly and updated to reflect changes in the institution's technological landscape and operational dependencies.

4.4 Vendor Risk Management

Institutions must establish a process for assessing and managing the risks associated with third-party vendors who process, transmit, handle, or store institutional information.

Public

Section 5: *Security Incident Notification*

Policy Objective: Establish a comprehensive and consistent approach to the detection, escalation, notification and reporting of security events and incidents, ensuring adherence to all laws, regulations and legal obligations. Promote SUNY-wide communication, collaboration, and mobilization of resources to mitigate the impact of such events.

5.1 System Administration Notification

Institutions must notify the SUNY CISO of any known or suspected cybersecurity event that:

- Impacts the institution and requires the institution to notify any regulatory authority, state or federal government agency, or any other supervisory body.
- Has a reasonable likelihood of materially harming the normal operations of the institution.
- Results in the deployment of ransomware within the institution's information systems.
- Results in the exposure of sensitive SUNY information.

Notifications must be made as soon as practicable and provide pertinent details of the event or incident, such as the incident's business and operational impact, indicators of compromise associated with the incident, and remediation actions being undertaken.

Section 6: *Access Management*

Policy Objective: Use processes and tools to securely assign and manage authorization to credentials for user accounts, administrator accounts, and service accounts.

6.1 Account Management

Institutions must establish an account management process that allows for access to sensitive information and critical systems to be granted in accordance with the principle of least privilege. Institutions must implement a structured and auditable process for the creation, modification, disablement, and deletion of accounts. Institutions must perform periodic account reviews based on risk, access, and behavior with a particular focus on privileged and service accounts.

6.2 Passwords

Institutions must implement mechanisms to properly identify system users, processes acting on behalf of users, or devices, and authenticate the identities of those users, processes, or devices. Institutions must use unique passwords for all enterprise assets.

Passwords must, at a minimum, be no shorter than 8-characters for accounts protected by Multi-Factor Authentication (MFA) and 14-characters for accounts not protected by MFA.

6.3 Multifactor Authentication

Institutions must implement MFA for:

- Remote privileged account access.
- Remote network account access.
- Virtual Private Network (VPN) access.
- Access to SUNY federated applications.
- Access to institutional email.

Section 7: *Data Backups*

Policy Objective: Implement and establish a documented and systemic process for backing up institutional data. The process must ensure the continuity of operations, minimization of data loss, and provide the institution assurance in the integrity and availability of information systems and assets.

7.1 Routine Backups and Cadence

Institutions must perform regular backups of system and user information. The frequency and scope of the backups must be determined based on the sensitivity of the data and the criticality of operational systems.

7.2 Protect Backups

Backup data must be protected with equivalent controls to the original data.

7.3 Tamper-Proof Backups

All backup systems and processes must incorporate measures to prevent unauthorized modification or tampering of backed-up data.

7.4 Backup Testing

Backups must be tested regularly to ensure they can be restored with minimal disruption to the institution in the event of a disaster.

7.5 Off-Site Storage

Institutions must ensure recovery data is stored at a secure alternative logical or physical location.

Public

Section 8: *Data Encryption*

Policy Objective: Institutions must use encryption to protect the confidentiality and integrity of sensitive institutional data. Where such measures are not feasible, institutions must document exceptions and deploy appropriate compensating controls.

8.1 Encryption at Rest

All sensitive institutional information must be encrypted when stored on any device, system, or storage medium. This includes, but is not limited to, databases, file servers, backup media, and end-user devices.

8.2 Encryption in Transit

All sensitive institutional information must be encrypted during transmission over networks, whether internal or external. This includes email communications, file transfers, and web traffic containing sensitive data.

8.3 Up-to-Date Encryption Methods

Institutions must ensure all encryption of sensitive information utilizing current, industry-standard encryption methods and protocols. Encryption algorithms and key lengths must be regularly reviewed

and updated to maintain effectiveness against evolving threats. Institutions must maintain documentation of all systems incapable of using non-deprecated algorithms or protocols.

8.4 Key Management

Institutions must implement and maintain secure processes for managing encryption keys throughout their lifecycle, including secure key generation, storage, distribution, rotation, and destruction.

Section 9: *Firewalls*

Policy Objective: Implement and maintain next generation firewall systems with procedures to control, monitor, and protect network traffic across all organizational boundaries, ensuring the confidentiality, integrity, and availability of data while defending against unauthorized access and potential security threats.

9.1 Implementation

Institutions must maintain firewalls with the following capabilities:

- Packet filtering.
- Stateful inspection.
- Threat indicator feed ingestion.
- Application and user detection.
- Intrusion prevention.
- Alerting and notification.

Public

9.2 Configuration and Operation

Institutions must deploy, configure, and maintain firewalls in accordance with manufacturer recommended setting and relevant SUNY IT standards. Institutions must establish a process for investigating, prioritizing, and escalating firewall alerts.

9.3 Assessment and Auditing

Institutions must periodically evaluate the control effectiveness of the firewall. Institutions must annually review firewalls to remove ineffective or deprecated policies or rules.

Section 10: *Network Infrastructure Management*

Policy Objective: Establish, implement, and manage network devices to prevent attackers from exploiting vulnerable network services and access points.

10.1 Network Segmentation

Institutions must design, implement, and maintain a network segmentation plan that ensures critical systems and sensitive data are logically separated from other network resources. The segmentation implementation must include:

- Technologies used to create distinct network segments.
- Protocols for data flow between segments.
- A process for regular architecture reviews.

10.2 Remote Access Security

Institutions must implement and enforce a remote access policy that ensures secure, authenticated, and monitored connections to institutional resources from external locations.

10.3 Third-Party Network Access Management

Institutions must ensure access to institutional networks by third parties is monitored, reviewed, and limited to only those network resources required to perform the service function.

10.4 Distributed Denial of Service (DDoS) Protection

Institutions must implement and maintain comprehensive Distributed Denial of Service (DDoS) protection measures. These measures must include dedicated mitigation solutions and formalized response plans.

Public

Section 11: *Network and Endpoint Security*

Policy Objective: Develop processes and tools to establish and maintain network and endpoint monitoring and defense against security threats across the enterprise's network infrastructure and user base.

11.1 Log Aggregation and Management

Institutions must implement a centralized log aggregation and analysis system that provides security event alerting. The log analysis solution must also enable the correlation and contextualization of system alerts with other relevant network and system events. Institutions must implement and establish procedures for investigating, prioritizing, and escalating security alerts generated by the log analysis system.

11.2 Endpoint Detection and Response Deployment

Institutions must install endpoint detection and response (EDR) tools on all institutionally managed computer systems, including desktops, laptops, servers, and other computing devices that are used by staff, faculty, contractors, and third-party vendors of the organization.

11.3 Continuous Monitoring and Incident Response

Institutions must ensure that either campus staff or a third-party service is monitoring, responding to, and remediating, if necessary, security alerts 24 hours a day.

Section 12: *Vulnerability Management*

Policy Objective: Continuously assess, track, and remediate vulnerabilities on enterprise assets to minimize the window of opportunity for attackers.

12.1 Vulnerability Remediation Process

Institutions must establish and maintain a formal process for addressing identified vulnerabilities, including:

- Assigning responsibility for remediation to appropriate personnel or teams.
- Setting target timeframes for remediation based on vulnerability severity.
- Implementing a tracking system to monitor the progress of remediation efforts.
- Conducting follow-up scans to verify successful remediation.
- Accepting exceptions, implementing compensating controls, and regularly reviewing exceptions.

12.2 Regular Vulnerability Assessment

Institutions must perform automated vulnerability scans of internal and externally-exposed enterprise assets on a regular basis.

- Vulnerability scans must cover all network-connected devices, including servers, workstations, network devices.
- Must perform both authenticated and unauthenticated scans.
- Vulnerability scan results must be documented and retained for audit purposes.

12.3 Patch Management Standards

Institutions must implement a patch management process for remediating system and software vulnerabilities. The patch management process must establish patching cadences based on the severity of identified vulnerabilities and leverage automation to the greatest extent possible.

Section 13: *Incident Response*

Policy Objective: Develop and maintain an incident response capability, including policies, plans, procedures, defined roles, training, and communications, to prepare, detect, and quickly respond to an attack.

13.1 Incident Response Plan

The Institution must establish a comprehensive plan for responding to security incidents. This plan must include:

- Individuals and agencies requiring notification in the event of an incident.
- Detailed procedures for responding to various types of incidents.
- A process for preserving and collecting evidence.
- Procedures for containing the breach and minimizing damage.
- A list of resources and tools necessary for incident response.

13.2 Annual Review and Testing

The incident response plan must be reviewed and tested annually to ensure its effectiveness. The review process must include updates to reflect changes in the institutional environment, threat landscape, and legal requirements.

Testing should include tabletop exercises and simulated incidents to evaluate team readiness.

Section 14: *Definitions*

Information Criticality: Describes how valuable and important the information is in relation to the purpose and ongoing operations of SUNY. Criticality evaluates how data loss, corruption, or inaccessibility will affect SUNY's operations, standing, adherence to the law, and general functionality. SUNY criticality levels of information (Non-critical, Critical, and Mission-Critical)—are used to categorize it.

Information Sensitivity: Is the level of protection required for information because it is private or confidential. Sensitive information can include financial records, staff details, research data, and student records. Information sensitivity is classified into levels (Public, Private, Restricted) based on the possible consequences of unapproved disclosure, modification, or destruction.

Institution: Refers to a state operated campus, statutory college, or community college and all affiliates for which the campus assumes operational responsibility, as it relates to information security.

Qualified Individual: The qualified individual can be an employee of the institution, its affiliate, or a service provider. In many cases, the institution's qualified individual will be its chief information security officer, chief compliance officer, or someone in a similar role. More important than the qualified individual's specific institutional role is that the qualified individual have the appropriate experience and authority to oversee the institution's security program, make necessary changes to that program, and report candidly to the board of directors or other governing body about the institution's security compliance and risks

Risk Profile: Refers to the comprehensive vulnerability of the institution information assets to potential attacks. The risk profile encompasses the identification and evaluation of diverse risks, taking into consideration variables such as the probability of security breaches and the possible repercussions on the functioning, standing, and regulatory responsibilities of the institution. It includes cyber threats, data

breaches, loss of data integrity, and system delays, among other potential hazards. Constant reevaluation is necessary to account for developments in technology, threat environments, and institution operations that impact the risk profile.

Risk Tolerance: The institution's preparedness to tolerate the potential adverse repercussions of security threats in the absence of substantial measures to alleviate them. To ascertain risk tolerance, one must weigh the potential consequences of security incidents against the expense of implementing security measures. The institution's strategic objectives, financial resources, regulatory obligations, and cultural perspectives on risk all exert an impact on it. To safeguard its information assets, a university with a low risk tolerance will allocate a greater budget towards security measures. Conversely, a university with a higher risk tolerance might be willing to take improved operational flexibility or reduced costs in return for increased risk exposure.

Sensitive Information: common term for data classified as Restricted (High Impact) or Private (Moderate Impact) security classification used by the Institution to name in aggregate the formally declared set of *standards*-level categories of information, such as Social Security Number, being addressed, i.e., protected, by the Program.

Other Related Information

State University of New York IT Standards Policy 6608

Records Schedules governing retention and disposition of information at SUNY Institutions:

- State-operated institutions:
 - [SUNY Records Retention and Disposition Policy 6609](#) (listed in the appendices to the SUNY Records Policy)
 - [New York State General Retention and Disposition Schedule for New York State Government Records](#)
- Community Colleges:
 - [LGS-1 Local Government Records Schedule](#) followed by all community colleges
 - Federal Educational Rights and Privacy Act (FERPA) - Information available on the [SUNY Compliance FERPA webpage](#)

Health Insurance Portability and Accountability Act (HIPAA) - Information available on the [SUNY Compliance HIPAA webpage](#)

Gramm- Leach- Bliley Act - Information available on the [SUNY Compliance GLBA webpage](#)

NIST SP 800-60 Rev. 1: Guide for Mapping Types of Information and Information Systems to Security Categories

Payment Card Industry Data Security Standard (PCI DSS)

NYS Information Security Breach & Notification Law (Section 208 of the State Technology Law)

NYS Business Law and Technology Law

NYS Governmental Accountability, Audit & Internal Control Act

NYS Education Law, including, but not limited to, §6304(12), relating to electronic transactions at the community colleges

Procedures

[SUNY Procedure Document No. 6610](#) - Legal Proceeding Preparation (E-Discovery) Procedure

[SUNY Document No. 6601](#) - Compliance with Freedom of Information Law (FOIL).

Related Policies

[SUNY Policy Document No. 6609](#) - Records Retention and Disposition Policy, with [Introduction to the SUNY Records Retention and Disposition Schedule](#).

[SUNY Data Transparency Policy](#).

Public

Forms

There are no forms relevant to this policy.

Authority

[State University of New York Board of Trustees Resolution, No. 2024-48](#)

[NYS Education Law §351, NY EDN Title 1, Article 8, §351 \(State University Mission\)](#).

In case of questions, readers are advised to refer to the New York State Legislature site for the menu of the [Laws of New York State](#).

History

In September 2016, the State University Board of Trustees authorized the Chancellor to establish the first SUNY organization-wide Information Security Policy. This revision is the first major update to that policy since its initial release.

Public